

## Penetration Testing Report

HEADLESS

Riccardo Napoli | Corso di PTEH | A.A. 2023/2024



**UNIVERSITÀ DEGLI STUDI DI SALERNO**  
**DIPARTIMENTO DI INFORMATICA**

# Indice

|          |                              |          |
|----------|------------------------------|----------|
| <b>1</b> | <b>Executive Summary</b>     | <b>1</b> |
| <b>2</b> | <b>Engagement Highlights</b> | <b>1</b> |
| <b>3</b> | <b>Vulnerability Report</b>  | <b>2</b> |
| <b>4</b> | <b>Remediation Report</b>    | <b>3</b> |
| <b>5</b> | <b>Findings Summary</b>      | <b>4</b> |
| <b>6</b> | <b>Detailed Summary</b>      | <b>5</b> |
| 6.1      | Priorità alta . . . . .      | 5        |
| 6.2      | Priorità media . . . . .     | 7        |
| 6.3      | Priorità bassa . . . . .     | 9        |

# 1 Executive Summary

Il seguente report espone i risultati del processo di penetration testing condotto sulla macchina "**Headless**" della piattaforma **HackTheBox**. Il penetration testing è stato commissionato per il corso di *Penetration Testing and Ethical Hacking* dell'*Università degli Studi di Salerno*. L'obiettivo è stato quello di esaminare la sicurezza di Headless con lo scopo di identificare, analizzare, sfruttare e documentare quante più vulnerabilità possibili tra quelle presenti.

Il processo di penetration testing è stato avviato il 30/06/24 e si è concluso il 10/08/24. L'approccio utilizzato è stato di tipo **black-box**: al pentester non sono state fornite informazioni di alcun tipo sull'asset, potendo così simulare in toto il comportamento di un attaccante. Durante il processo di penetration testing si sono utilizzati sia approcci manuali che automatici attraverso l'utilizzo di software d'uso frequente nel campo, in modo tale da individuare eventuali vulnerabilità, comprendere come un attaccante possa sfruttarle per eludere le difese dell'asset e stimare l'impatto di quest'ultime in caso di una violazione di sicurezza. A seguito del penetration test sono state individuate numerose vulnerabilità che, in alcuni casi, potrebbero anche fornire ad un attaccante il controllo completo dell'asset.

Il presente documento si propone di analizzare tutte le vulnerabilità rilevate e di riportare tutte le possibili mitigazioni atte a ridurre il rischio e ad innalzare in modo non indifferente la postura di sicurezza.

## 2 Engagement Highlights

Siccome la seguente è un'attività di penetration testing condotta a fini didattici, non è stato istituito alcun canale di comunicazione tra il pentester e il cliente e non sono stati imposti nè budget nè restrizioni legali o tecniche sull'impatto del testing. Per lo stesso motivo, non sono stati siglati accordi di Non-Disclosure Agreement (NDA). Per eseguire il processo di penetration testing è stata utilizzata una macchina Kali Linux, la quale risulta essere provvista di una gran parte di strumenti adatti allo scopo. L'approccio utilizzato ai fini del testing si basa su un framework composto dalle seguenti fasi:

1. Target scoping;
2. Information gathering;
3. Target discovery;
4. Enumerating target;
5. Vulnerability mapping;

6. Target exploitation;
7. Privilege escalation;
8. Maintaining access;
9. Reporting.

Questo rapporto illustra solo l'ultima delle fasi. Per una descrizione più approfondita delle altre fasi, è possibile consultare il documento "Penetration Testing Narrative".

### 3 Vulnerability Report

Le vulnerabilità trovate durante il processo di penetration testing sono legate principalmente a configurazioni errate o a controlli non effettuati durante l'implementazione della Web Application presente sulla macchina. Un attaccante potrebbe sfruttare le seguenti falle di sicurezza per ottenere informazioni sul target o persino ottenere l'accesso parziale o totale all'asset inserendo una shell con permessi di root.

Le principali debolezze individuate sono le seguenti:

- **XSS nell'avviso di hacking - Livello criticità: ALTO**
  - Nella pagina di avviso di tentato hacking, un utente può inserire codice malevolo che verrà eseguito quando un amministratore interagirà con la Web App, mettendo a rischio la divulgazione di informazioni sensibili.
- **Injection di comandi nel form amministratore - Livello criticità: ALTO**
  - Non è stato effettuato alcun controllo sui caratteri speciali (lato server) rispetto al contenuto dei campi dei form presenti sulla piattaforma. Un attaccante potrebbe iniettare sequenze particolari di codice al fine di sfruttare altre vulnerabilità.
- **File con permessi ingiustamente elevati - Livello criticità: MEDIO**
  - Il file `usr/bin/syscheck` può essere eseguito con privilegi da amministratore dall'utente `dvir`. Una volta ottenuto l'accesso come utente, è facile l'elevazione dei privilegi.
- **Mancanza dell'attributo `HttpOnly` per il cookie - Livello criticità: MEDIO**

- Questo attributo è una misura di sicurezza atta ad evitare attacchi di tipo Cross-Site Scripting: senza questo attributo, eventuali cookie sulla Web App risulterebbero leggibili e modificabili da codice Javascript lato client.
- **Presenza di file con credenziali in chiaro - Livello criticità: MEDIO**
  - Navigando tra i file una volta ottenuto accesso livello utente è possibile ritrovare un file php contenente username e password completamente in chiaro. Un attaccante potrebbe usare le suddette credenziali per autenticarsi ai servizi.
- **Mancanza di alcuni header nella Web App. Livello criticità: BASSO**
  - **Mancanza dell'header X-Frame-Options.** È una misura di sicurezza per impedire attacchi di clickjacking, ove un attaccante potrebbe indurre un utente a cliccare su link ingannevoli involontariamente, creando un sito malevolo e incorporando Headless in un frame.
  - **Mancanza dell'header X-Content-Type-Options.** È un header utilizzato per impedire attacchi di tipo MIME-sniffing. Senza questo header, un attaccante potrebbe "ingannare" i web browser nell'interpretare i file in modo differente dalla loro originale intenzione, portando a problemi di sicurezza.

## 4 Remediation Report

Per ristabilire una sicurezza più elevata dell'asset, si indicano le seguenti misure:

- Risolvere tutte le vulnerabilità presentate in questo documento, a partire dalla più critica per poi procedere con quelle di priorità inferiore;
- Controllare che ogni input lato utente venga correttamente sanificato;
- Aggiornare regolarmente ogni software presente sul sistema;
- Rimuovere dati sensibili da file accessibili ad utenti non autorizzati;
- Pianificare regolari Security Audits per controllare frequentemente la postura di sicurezza del sistema.

## 5 Findings Summary

Il processo di penetration testing, condotto usando sia tecniche manuali che automatiche, ha rilevato diverse vulnerabilità. In particolare, sono state individuate 15 vulnerabilità, di cui 3 a rischio alto, 5 a medio rischio e 7 a rischio basso. Le vulnerabilità riscontrate saranno classificate secondo quattro possibili livelli di gravità in base al CVSS v3.0:

- **Basso (Low):** Vulnerabilità di basso rischio su confidenzialità, integrità e disponibilità del sistema ( $CVSS < 4.0$ );
- **Medio (Medium):** Vulnerabilità potenzialmente grave per il sistema ed i dati ( $4.0 \leq CVSS < 6.0$ );
- **Alto (High):** Vulnerabilità grave per il sistema, con conseguenze potenzialmente molto dannose ( $6.0 \leq CVSS < 9.0$ );
- **Critico (Critical):** Vulnerabilità dal più alto tasso di rischio con impatti molto gravi su sistema e dati ( $CVSS \geq 9.0$ ).

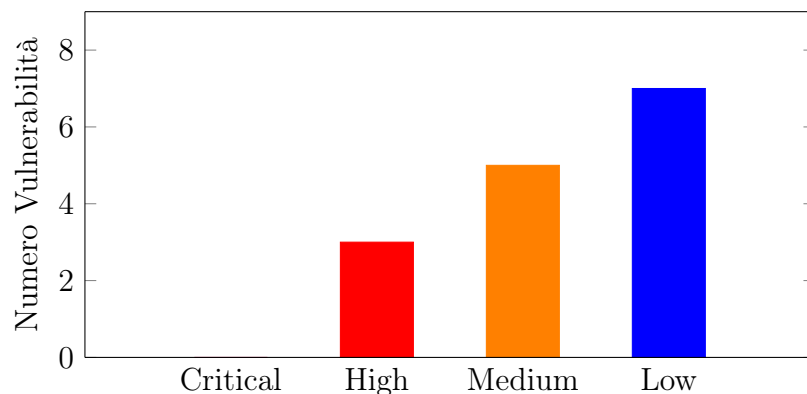


Figura 1: Numero di vulnerabilità per gravità

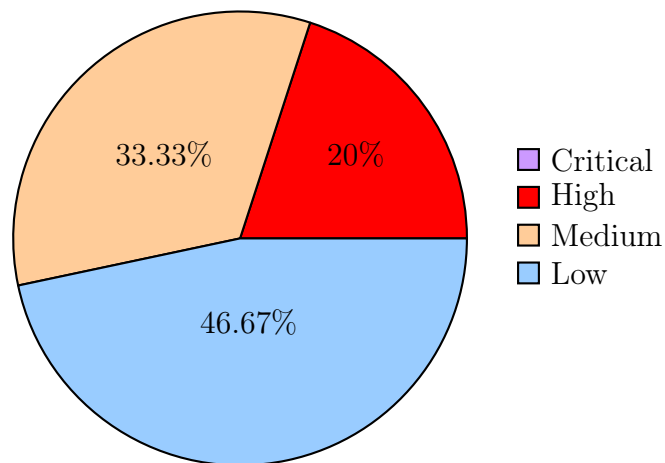


Figura 2: Percentuale di vulnerabilità per gravità

## 6 Detailed Summary

### 6.1 Priorità alta

|                                     |                                                                                                                                                                                                                                                                |
|-------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Versione Werkzeug non sicura</b> |                                                                                                                                                                                                                                                                |
| <b>High</b>                         |                                                                                                                                                                                                                                                                |
| <b>CVE</b>                          | <b>2023-25577 [2], 2023-23934 [1], 2024-34069 [4], 2023-46136 [3]</b>                                                                                                                                                                                          |
| <b>Descrizione:</b>                 | La versione del server Werkzeug installata sulla macchina è vulnerabile a diversi attacchi che potrebbero portare anche all'esecuzione di codice arbitrario all'insaputa dell'utente.                                                                          |
| <b>Rischi:</b>                      | Tali vulnerabilità consentono di effettuare attacchi DoS sfruttando i multipart file di Werkzeug, di bypassare l'accesso tramite cookie di determinate webapp o anche di eseguire codice malevolo a seguito della mancata protezione ad attacchi di tipo CSRF. |
| <b>Soluzione:</b>                   | Aggiornare il server ad una versione sicura.                                                                                                                                                                                                                   |
| <b>Metodo di detection:</b>         | Individuata manualmente.                                                                                                                                                                                                                                       |

| Applicazione vulnerabile a XSS |                                                                                                                                                                        |
|--------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| High                           |                                                                                                                                                                        |
| CVE                            | –                                                                                                                                                                      |
| Descrizione:                   | Non sono stati effettuati controlli sui caratteri speciali sui campi dei form presenti sulla piattaforma.                                                              |
| Rischi:                        | Un attaccante potrebbe iniettare comandi Javascript eseguibili lato server, mettendo a rischio la sicurezza dell'intero sistema.                                       |
| Soluzione:                     | Filtrare tutti i caratteri speciali nei campi dei form presenti sulla Web app. I controlli sui caratteri speciali andranno effettuati sia lato client che lato server. |
| Metodo di detection:           | Individuata manualmente.                                                                                                                                               |

| Injection di comandi nella dashboard di amministratore |                                                                                                                                                                                 |
|--------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| High                                                   |                                                                                                                                                                                 |
| CVE                                                    | –                                                                                                                                                                               |
| Descrizione:                                           | Non sono stati effettuati controlli sul campo "date" del report di sistema presente sulla dashboard di amministratore.                                                          |
| Rischi:                                                | Un attaccante potrebbe iniettare nel campo citato comandi arbitrari lato server, mettendo a rischio la sicurezza dell'intero sistema.                                           |
| Soluzione:                                             | Effettuare escaping di ogni tipo di input malevolo nei parametri della richiesta web della dashboard di amministratore al fine di prevenire attacchi di tipo command injection. |
| Metodo di detection:                                   | Individuata manualmente.                                                                                                                                                        |



## 6.2 Priorità media

| File con permessi ingiustamente elevati |                                                                                                                           |
|-----------------------------------------|---------------------------------------------------------------------------------------------------------------------------|
| Medium                                  |                                                                                                                           |
| <b>CVE</b>                              | —                                                                                                                         |
| <b>Descrizione:</b>                     | Il file <code>usr/bin/syscheck</code> può essere eseguito con privilegi da amministratore dall'utente <code>dvir</code> . |
| <b>Rischi:</b>                          | Una volta ottenuto l'accesso da utente, è facile l'elevazione dei privilegi modificando lo script che il file chiama.     |
| <b>Soluzione:</b>                       | Abbassare i privilegi del file <code>usr/bin/syscheck</code> .                                                            |
| <b>Metodo di detection:</b>             | Individuata manualmente.                                                                                                  |

| Applicazione web potenzialmente vulnerabile a Clickjacking |                                                                                                                                                                                                   |
|------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Medium                                                     |                                                                                                                                                                                                   |
| <b>CVE</b>                                                 | —                                                                                                                                                                                                 |
| <b>Descrizione:</b>                                        | Il server web non imposta l'header <code>X-Frame-Options</code> in tutte le risposte http. Ciò potrebbe esporre il sito a un attacco di clickjacking.                                             |
| <b>Rischi:</b>                                             | Un aggressore potrebbe indurre un utente a cliccare su un'area della pagina differente da quella che l'utente pensa sia. Questo può portare l'utente a eseguire azioni dannose involontariamente. |
| <b>Soluzione:</b>                                          | Restituire l'header <code>HTTP X-Frame-Options</code> con la risposta della pagina.                                                                                                               |
| <b>Metodo di detection:</b>                                | Individuata tramite Nessus.                                                                                                                                                                       |

| Presenza di file con credenziali in chiaro |                                                                                                                                              |
|--------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------|
| Medium                                     |                                                                                                                                              |
| <b>CVE</b>                                 | —                                                                                                                                            |
| <b>Descrizione:</b>                        | Ottenendo il controllo da remoto della macchina target, è possibile accedere a file che contengono username e password di servizi in chiaro. |
| <b>Rischi:</b>                             | Un attaccante potrebbe scovare le credenziali per autenticarsi ai relativi servizi.                                                          |
| <b>Soluzione:</b>                          | Implementare una migliore politica di gestione delle password.                                                                               |
| <b>Metodo di detection:</b>                | Individuata manualmente.                                                                                                                     |

| Mancanza dell'header X-Content-Type-Options |                                                                                                                                                                                                                                                                                                           |
|---------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Medium                                      |                                                                                                                                                                                                                                                                                                           |
| <b>CVE</b>                                  | —                                                                                                                                                                                                                                                                                                         |
| <b>Descrizione:</b>                         | La web app non imposta l' header di sicurezza X-Content-Type-Options, progettato per indicare ai browser come gestire il contenuto scaricato.                                                                                                                                                             |
| <b>Rischi:</b>                              | Senza questo header, i browser potrebbero tentare di determinare autonomamente il tipo di contenuto attraverso una pratica chiamata MIME-sniffing. Un attaccante può far interpretare ai browser file inoffensivi come pericolosi, potenzialmente compromettendo la sicurezza del sistema e degli utenti. |
| <b>Soluzione:</b>                           | Restituire l'header HTTP X-Content-Type-Options.                                                                                                                                                                                                                                                          |
| <b>Metodo di detection:</b>                 | Individuata manualmente.                                                                                                                                                                                                                                                                                  |

| Mancanza dell'header HttpOnly per il cookie isadmin |                                                                                                                                                                                      |
|-----------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Medium                                              |                                                                                                                                                                                      |
| <b>CVE</b>                                          | —                                                                                                                                                                                    |
| <b>Descrizione:</b>                                 | Riguardo il cookie "isadmin" della Web App, non viene utilizzato questo header di sicurezza progettato per rendere il cookie illegibile non modificabile tramite comandi javascript. |
| <b>Rischi:</b>                                      | Un attaccante può sfruttare questo attaccante per effettuare attacchi di tipo Cross-site Scripting (XSS), potenzialmente compromettendo la sicurezza della web app.                  |
| <b>Soluzione:</b>                                   | Restituire l'header HttpOnly per il cookie isadmin.                                                                                                                                  |
| <b>Metodo di detection:</b>                         | Individuata tramite OpenVAS.                                                                                                                                                         |

### 6.3 Priorità bassa

| Algoritmi MAC deboli supportati (SSH) |                                                                                                                                 |
|---------------------------------------|---------------------------------------------------------------------------------------------------------------------------------|
| Low (2.6)                             |                                                                                                                                 |
| <b>CVE</b>                            | —                                                                                                                               |
| <b>Descrizione:</b>                   | Il server SSH sulla macchina è configurato per consentire/supportare algoritmi di Message Authentication Code (MAC) deboli.     |
| <b>Rischi:</b>                        | Se per la comunicazione SSH venissero usati algoritmi deboli, la sicurezza della comunicazione potrebbe essere messa a rischio. |
| <b>Soluzione:</b>                     | Disabilitare gli algoritmi umac-64-etm e umac-64.                                                                               |
| <b>Metodo di detection:</b>           | Individuata tramite OpenVAS.                                                                                                    |

| Password non conformi agli standard di sicurezza |                                                                                                                                                                                           |
|--------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Low                                              |                                                                                                                                                                                           |
| <b>CVE</b>                                       | —                                                                                                                                                                                         |
| <b>Descrizione:</b>                              | Alcune delle password utilizzate dagli amministratori sono di scarsa lunghezza e composte da parole di senso compiuto, prive di numeri o caratteri speciali.                              |
| <b>Rischi:</b>                                   | Un attaccante potrebbe trovare la password di alcuni servizi che la macchina offre mediante tecniche di password cracking.                                                                |
| <b>Soluzione:</b>                                | Formare il personale sull'uso di password complesse e implementare controlli a livello software per utilizzare password più lunghe e con sequenze di lettere, cifre e caratteri speciali. |
| <b>Metodo di detection:</b>                      | Individuata manualmente.                                                                                                                                                                  |

| Divulgazione di informazioni tramite TCP Timestamp |                                                                                                     |
|----------------------------------------------------|-----------------------------------------------------------------------------------------------------|
| Low (2.6)                                          |                                                                                                     |
| <b>CVE</b>                                         | —                                                                                                   |
| <b>Descrizione:</b>                                | L'host remoto risponde a richieste timestamp TCP.                                                   |
| <b>Rischi:</b>                                     | Un attaccante potrebbe sfruttare i timestamp TCP per conoscere il tempo di attività della macchina. |
| <b>Soluzione:</b>                                  | Disabilitare i timestamp TCP.                                                                       |
| <b>Metodo di detection:</b>                        | Individuata tramite OpenVAS.                                                                        |

| Divulgazione di informazioni tramite ICMP Timestamp |                                                                                            |
|-----------------------------------------------------|--------------------------------------------------------------------------------------------|
| Low (2.1)                                           |                                                                                            |
| <b>CVE</b>                                          | <b>CVE-1999-0524 [5]</b>                                                                   |
| <b>Descrizione:</b>                                 | L'host remoto risponde a richieste ICMP timestamp.                                         |
| <b>Rischi:</b>                                      | Un attaccante potrebbe sfruttare i timestamp per superare autenticazioni basate sul tempo. |
| <b>Soluzione:</b>                                   | Filtrare le richieste timestamp ICMP.                                                      |
| <b>Metodo di detection:</b>                         | Individuata tramite OpenVAS.                                                               |

| Cookie senza attributo SameSite |                                                                                                                                                                      |
|---------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Low                             |                                                                                                                                                                      |
| <b>CVE</b>                      | —                                                                                                                                                                    |
| <b>Descrizione:</b>             | Il cookie isadmin della web app non possiede l'attributo SameSite.                                                                                                   |
| <b>Rischi:</b>                  | Senza l'attributo SameSite, il cookie può essere inviato come risultato di una richiesta "cross-site", che può portare a compromissioni sulla sicurezza del sistema. |
| <b>Soluzione:</b>               | Aggiungere attributo SameSite al cookie isadmin.                                                                                                                     |
| <b>Metodo di detection:</b>     | Individuata tramite OWASP ZAP.                                                                                                                                       |

| Divulgazione di informazioni - Messaggi di debug |                                                                                                               |
|--------------------------------------------------|---------------------------------------------------------------------------------------------------------------|
| Low                                              |                                                                                                               |
| <b>CVE</b>                                       | —                                                                                                             |
| <b>Descrizione:</b>                              | La risposta dell'host remoto contiene messaggi di debug comuni restituiti da determinati tipi di piattaforme. |
| <b>Rischi:</b>                                   | Un attaccante potrebbe sfruttare i messaggi di debug per carpire informazioni ulteriori riguardo il sistema.  |
| <b>Soluzione:</b>                                | Disattivare i messaggi di debug prima di rendere pubblica la Web Application.                                 |
| <b>Metodo di detection:</b>                      | Individuata tramite OWASP ZAP.                                                                                |

| Divulgazione di informazioni - Campo "Server" delle risposte HTTP |                                                                                                        |
|-------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------|
| Low                                                               |                                                                                                        |
| <b>CVE</b>                                                        | —                                                                                                      |
| <b>Descrizione:</b>                                               | L'host remoto sta facendo trapelare informazioni sulla versione il campo "Server" della risposta HTTP. |
| <b>Rischi:</b>                                                    | L'accesso a tali informazioni può facilitare l'identificazione di altre vulnerabilità del server.      |
| <b>Soluzione:</b>                                                 | Assicurarsi che il server web sia configurato in modo da non restituire l'header "Server".             |
| <b>Metodo di detection:</b>                                       | Individuata tramite OWASP ZAP.                                                                         |

## Riferimenti bibliografici

- [1] CVE.org. *CVE-2023-23934*. URL: <https://www.cve.org/CVERecord?id=CVE-2023-23934>.
- [2] CVE.org. *CVE-2023-25577*. URL: <https://www.cve.org/CVERecord?id=CVE-2023-25577>.
- [3] CVE.org. *CVE-2023-46136*. URL: <https://www.cve.org/CVERecord?id=CVE-2023-46136>.
- [4] CVE.org. *CVE-2024-34069*. URL: <https://www.cve.org/CVERecord?id=CVE-2024-34069>.
- [5] NIST. *CVE-1999-0524*. URL: <https://nvd.nist.gov/vuln/detail/CVE-1999-0524>.